

ZeniaHR Mobile API Handover

Project Name

ZeniaHR Mobile Platform

Mobile API Version

1.0.0

Production Status

LIVE

Live Base URL

Production: <http://13.233.82.210/api>

API Version

v1

Authentication Types

- **Company Head / HR:** Email + Password -> Email OTP -> JWT
- **Employee:** Mobile Number -> SMS OTP -> JWT

Supported Roles

- Super Admin
- Company Head
- HR
- Employee

Folder Structure

See current directory for API endpoints, sequence flows, and Flutter integration notes.

Contact Information

ZeniaHR Backend Team

Integration Order

1. Splash
2. Company Login
3. Employee Login
4. OTP
5. Dashboard
6. Employee Directory
7. Employee Profile
8. Notifications
9. Settings
10. Logout

API Documentation Summary

API	Method	URL	Auth Required
Admin Login	POST	/auth/login	No
Admin Verify	POST	/auth/verify-otp	No
Admin Refresh	POST	/auth/refresh	Yes
Admin Logout	POST	/auth/logout	Yes
Admin Logout All	POST	/auth/logout-all	Yes
Employee Login	POST	/employee/login	No
Employee Verify	POST	/employee/verify-otp	No
Employee Logout	POST	/employee/logout	Yes
Employee Logout All	POST	/employee/logout-all	Yes
Dashboard	GET	/dashboard	Yes
Profile (Get)	GET	/profile	Yes
Profile (Update)	PUT	/profile	Yes
Company	GET	/company	Yes
Notifications	GET	/notifications	Yes
Employees List	GET	/employees	Yes
Employees Search	GET	/employees/search	Yes
Employee Detail	GET	/employees/{id}	Yes

API Sequence Flow

Company Head / HR Auth Flow

1. **Email** -> Client prompts for email.
2. **Password** -> Client prompts for password.
3. **Login API** POST /auth/login -> Returns otpSessionId.
4. **Email OTP** -> User checks email.
5. **Verify API** POST /auth/verify-otp -> Returns token (JWT) and refreshToken.
6. **Dashboard API** GET /dashboard using Bearer <token>.

Employee Auth Flow

1. **Mobile Number** -> Client prompts for Mobile Number.
2. **Login API** POST /employee/login -> Returns otpSessionId.
3. **SMS OTP** -> User checks SMS.
4. **Verify API** POST /employee/verify-otp -> Returns token (JWT).
5. **Dashboard API** GET /dashboard using Bearer <token>.

=====

COMPANY HEAD / HR LOGIN

=====

Endpoint
POST /auth/login

Purpose
Login Company Head or HR.

Authentication
No

Headers
Content-Type: application/json

Request Parameters

Parameter	Type	Required	Description
email	String	Yes	User Email
password	String	Yes	User Password

Sample Request

```
`json
{
  "email": "admin@company.com",
  "password": "Password@123"
}
```

Success Response

Status Code

200 OK

Response Parameters

Parameter	Type	Description
success	Boolean	API Status
otpRequired	Boolean	OTP Required
otpSessionId	String	OTP Session
message	String	Response Message

Sample Response

```
`json
{
  "success": true,
  "otpRequired": true,
  "otpSessionId": "sess_123456",
  "message": "OTP sent to email."
}
```

Error Responses

400

401

403

404

429

500

Sample Error JSON

```
`json
```

```
{
  "success": false,
  "error": "Invalid email or password."
}
```

=====

COMPANY HEAD / HR VERIFY OTP

=====

Endpoint
POST /auth/verify-otp

Purpose
Verify the Email OTP.

Authentication
No

Headers
Content-Type: application/json

Request Parameters

Parameter	Type	Required	Description
otpSessionId	String	Yes	Session ID from login
otp	String	Yes	6-digit OTP

Sample Request

```
`json
{
  "otpSessionId": "sess_123456",
  "otp": "123456"
}
```

Success Response
Status Code
200 OK

Response Parameters

Parameter	Type	Description
success	Boolean	API Status
token	String	JWT Token
refreshToken	String	Refresh Token
user	Object	User Details

Sample Response

```
`json
{
  "success": true,
  "token": "eyJhbG...",
  "refreshToken": "ref_...",
  "user": {
    "id": 1,
    "email": "admin@company.com",
    "role": "Company Head"
  }
}
```

Error Responses

400
401
500

Sample Error JSON

```
`json
{
  "success": false,
  "error": "Invalid or expired OTP."
}
```

=====
REFRESH TOKEN
=====

Endpoint
POST /auth/refresh

Purpose
Refresh JWT using Refresh Token.

Authentication
Yes

Headers
Authorization: Bearer <refresh_token>

Request Parameters
None

Sample Request
None

Success Response
Status Code
200 OK

Sample Response

```
`json
{
  "success": true,
  "token": "eyJhbG..."
}
```

Error Responses

401
500

=====
LOGOUT
=====

Endpoint
POST /auth/logout

Purpose
Logout the current device.

Authentication

Yes

Headers

Authorization: Bearer <jwt_token>

Request Parameters

None

Sample Request

None

Success Response

Status Code

200 OK

Sample Response

```
`json
{
  "success": true,
  "message": "Logged out successfully"
}
```

Error Responses

401

500

=====

LOGOUT ALL

=====

Endpoint

POST /auth/logout-all

Purpose

Logout from all devices.

Authentication

Yes

Headers

Authorization: Bearer <jwt_token>

Request Parameters

None

Sample Request

None

Success Response

Status Code

200 OK

Sample Response

```
`json
{
  "success": true,
  "message": "Logged out from all devices successfully"
}
```

Error Responses

=====

EMPLOYEE LOGIN

=====

Endpoint
POST /employee/login

Purpose
Login Employee via Mobile Number.

Authentication
No

Headers
Content-Type: application/json

Request Parameters

Parameter	Type	Required	Description
-----	-----	-----	-----
mobile	String	Yes	Employee Mobile Number

Sample Request

```
`json
{
  "mobile": "9876543210"
}
```

Success Response

Status Code

200 OK

Response Parameters

Parameter	Type	Description
-----	-----	-----
success	Boolean	API Status
otpRequired	Boolean	OTP Required
otpSessionId	String	OTP Session
message	String	Response Message

Sample Response

```
`json
{
  "success": true,
  "otpRequired": true,
  "otpSessionId": "sess_mob_123",
  "message": "OTP sent via SMS."
}
```

Error Responses

400

404

429

500

Sample Error JSON

```
`json
{
  "success": false,
  "error": "Employee not found."
}
```

=====

EMPLOYEE VERIFY OTP

=====

Endpoint
POST /employee/verify-otp

Purpose
Verify Employee SMS OTP.

Authentication
No

Headers
Content-Type: application/json

Request Parameters

Parameter	Type	Required	Description
otpSessionId	String	Yes	OTP Session
otp	String	Yes	6-digit OTP

Sample Request

```
`json
{
  "otpSessionId": "sess_mob_123",
  "otp": "123456"
}
```

Success Response

Status Code

200 OK

Sample Response

```
`json
{
  "success": true,
  "token": "eyJhbG...",
  "user": {
    "id": 12,
    "name": "John Doe",
    "mobile": "9876543210"
  }
}
```

Error Responses

400

500

=====

EMPLOYEE LOGOUT

=====

Endpoint
POST /employee/logout

Purpose
Logout the current device.

Authentication
Yes

Headers
Authorization: Bearer <jwt_token>

Success Response
Status Code
200 OK

Sample Response
`json
{
 "success": true,
 "message": "Logged out successfully"
}

=====

EMPLOYEE LOGOUT ALL

=====

Endpoint
POST /employee/logout-all

Purpose
Logout from all devices.

Authentication
Yes

Headers
Authorization: Bearer <jwt_token>

Success Response
Status Code
200 OK

Sample Response
`json
{
 "success": true,
 "message": "Logged out from all devices successfully"
}

=====

DASHBOARD

=====

Endpoint
GET /dashboard

Purpose
Fetch dashboard widgets and summary data.

Authentication
Yes

Headers
Authorization: Bearer <jwt_token>

Request Parameters
None

Sample Request
None

Success Response
Status Code
200 OK

Response Parameters

Parameter	Type	Description
success	Boolean	API Status
data	Object	Dashboard Widgets

Sample Response

```
`json
{
  "success": true,
  "data": {
    "attendanceSummary": {
      "present": 45,
      "absent": 5,
      "leave": 2
    },
    "upcomingBirthdays": [],
    "recentAnnouncements": []
  }
}
```

Error Responses
401
500

Sample Error JSON

```
`json
{
  "success": false,
  "error": "Unauthorized"
}
```

=====

COMPANY INFO

=====

Endpoint
GET /company

Purpose
Get company profile and policies.

Authentication
Yes

Headers
Authorization: Bearer <jwt_token>

Request Parameters
None

Sample Request
None

Success Response
Status Code
200 OK

Response Parameters

Parameter	Type	Description
success	Boolean	API Status
data	Object	Company Info

Sample Response

```
`json
{
  "success": true,
  "data": {
    "id": 1,
    "legalName": "Zenith Technologies",
    "logo": "https://..."
  }
}
```

Error Responses
401
500

Sample Error JSON

```
`json
{
  "success": false,
  "error": "Unauthorized"
}
```

=====

NOTIFICATIONS

=====

Endpoint
GET /notifications

Purpose
Fetch user notifications.

Authentication
Yes

Headers
Authorization: Bearer <jwt_token>

Request Parameters
None

Sample Request
None

Success Response
Status Code
200 OK

Response Parameters

Parameter	Type	Description
success	Boolean	API Status
data	Array	List of notifications

Sample Response

```
`json
{
  "success": true,
  "data": [
    {
      "id": 101,
      "title": "Leave Approved",
      "body": "Your sick leave was approved.",
      "read": false,
      "createdAt": "2026-08-04T10:00:00Z"
    }
  ]
}
```

Error Responses
401
500

Sample Error JSON

```
`json
{
  "success": false,
  "error": "Unauthorized"
}
```

Error Codes Mapping

Code	Meaning	Description
400	Bad Request	Validation failed, missing parameters, or invalid OTP.
401	Unauthorized	Missing or invalid JWT. User must re-login.
403	Forbidden	User authenticated but lacks required role/permission.
404	Not Found	Requested resource (User, Employee, etc.) does not exist.
409	Conflict	Data conflict (e.g., duplicate email/mobile).
422	Unprocessable Entity	Semantically incorrect payload.
429	Too Many Requests	Rate limit exceeded (e.g., too many OTP requests).
500	Server Error	Unhandled backend exception. Show generic error to user.

Flutter Integration Notes

API Execution Order

1. Call `login` endpoint first to get the OTP Session ID.
2. Call `verify-otp` with the Session ID to retrieve the JWT.
3. Once authenticated, call `/dashboard` and `/profile` to load the home screen.

JWT Storage

- Use **flutter_secure_storage** to store the token and refreshToken.
- DO NOT store tokens in SharedPreferences.

Token Refresh (Interceptors)

- Attach an interceptor (e.g. using Dio) to catch 401 Unauthorized.
- Upon 401, pause queued requests, call `/auth/refresh` with the refresh token.
- If refresh succeeds, update secure storage and retry queued requests.
- If refresh fails, log the user out and navigate to Splash/Login.

Authorization Header

- Prefix the token: `Authorization: Bearer <token>`.
- Required on ALL endpoints except `/login` and `/verify-otp`.

Timeout & Retry

- **Timeout:** Set a connection/receive timeout of **15,000ms** (15 seconds).
- **Retry:** Implement a max 3-retry policy for 5xx errors or network timeouts. Do NOT retry on 4xx errors (except 401 via refresh).